INFORME FINAL DE CIBERSEGURIDAD

TheNewfutures

Sistema de Gestión de Talleres en Convenio con INAU

Emiliano Sánchez · Líder / Scrum Master

Gabriel Rendon · Subcoordinador

Thiago Ferragut · Desarrollador frontend y backend

POLO Educativo Tecnológico San José

3º BT Informática · 2026 · Grupo 5

Asignatura: Electiva Ciberseguridad

Docente: Ana Victoria Reyes Macedo

Fecha de entrega: 5 de noviembre de 2026

Resumen

Este informe reúne el análisis, las medidas de protección y las pruebas de seguridad realizadas sobre el proyecto de TheNewfutures, una aplicación web para gestionar talleres, alumnos, asistencias, materiales, tareas, entregas e informes en tres perfiles: administrador, tallerista y alumno. El sistema utiliza un frontend en HTML, CSS, Bootstrap y JavaScript; una API REST en PHP 8.3 y Apache; MySQL 8.4; y contenedores Docker. Se revisaron las amenazas del proyecto, la arquitectura, las consultas a la base, la autenticación y los permisos por rol. Se documentan el hashing de contraseñas, JWT en cookie HttpOnly, controles de acceso, limitación de intentos, protección de adjuntos y endurecimiento de puertos y contenedores. La última ronda incorporada registra 38 casos aprobados, con limitaciones de pruebas manuales y datos de laboratorio. Los escaneos Nmap del 5 de noviembre identifican los servicios accesibles en localhost y en la dirección de red del servidor. El sistema no se presenta como certificado ni listo para datos reales: se incorporaron los Términos y Condiciones y la Política de Privacidad, con una casilla de aceptación, pero faltan su validación institucional y sus pruebas, el análisis SAST y la ejecución del script Bash en el entorno de laboratorio. También permanece pendiente habilitar HTTPS en el servidor de prueba y fortalecer controles adicionales.

Palabras clave: ciberseguridad, API REST, autenticación, control de acceso, Nmap

Índice

Resumen....2
Índice....3
Introducción....4
1.1. Metodología y fuentes....4
Descripción del sistema....6
2.1. Arquitectura y componentes....6
2.2. Tecnologías y organización....7
2.3. Datos tratados y alcance....7
2.4. Entorno y límites de la evaluación....8
Primera entrega: análisis y diseño seguro....8
3.1. Identificación de amenazas digitales....8
3.2. Mapa de riesgos....9
3.3. Matriz de probabilidad e impacto....10
3.4. Análisis de impacto....11
3.5. Buenas prácticas de seguridad aplicables....12
Segunda entrega: implementación segura, criptografía y aspectos legales....13
4.1. Hashing de contraseñas....13
4.2. Autenticación, JWT y gestión de la cookie....15
4.3. Términos y Condiciones y Política de Privacidad....17
4.4. Análisis estático de código (SAST)....19
Tercera entrega: hacking ético, pruebas y respuesta a incidentes....20
5.1. Análisis dinámico de vulnerabilidades web (DAST): Nmap....20
5.2. Auditoría automatizada de API mediante Bash....21
5.3. Registro de hallazgos y medidas correctivas....22
5.4. Plan de respuesta a incidentes....23
5.5. Reflexión ética y responsabilidad profesional....25
Conclusiones....26
Referencias....27
Anexos....32
Anexo A. Script prueba-seguridad.sh....32
Anexo B. Ejemplo de respuesta de adjuntos sin rutas internas....38
Anexo C. Documentos legales y evidencia de aceptación....39
Anexo D. Espacio de reflexión ética grupal....44

Introducción

TheNewfutures – Convenio con INAU es un proyecto académico de una plataforma web para centralizar la gestión de talleres socioeducativos en convenio con el Instituto del Niño y Adolescente del Uruguay (INAU). El Project Charter identifica a INAU como cliente y registra una entrevista inicial con Lemuel Szwec González, tallerista consultado como usuario experto. No acreditamos de contratación, adopción institucional ni operación oficial del sistema por parte de INAU; el entorno probado corresponde a un laboratorio del equipo (TheNewfutures, 2026).

La aplicación organiza el trabajo de tres perfiles. El administrador administra usuarios, talleres, inscripciones, asistencias e informes. El tallerista consulta los talleres asignados, registra asistencias, publica materiales y tareas y corrige entregas. El alumno consulta sus talleres, materiales, tareas, notas y asistencias, y realiza entregas. Las funciones efectivamente desarrolladas no se confunden con las que quedaron postergadas: entre ellas, la exportación de informes a PDF o Excel, que al cierre de la ronda Testing-06 continúa descargando JSON (TheNewfutures, 2026).

El objetivo de este informe es integrar las tres etapas solicitadas por la materia de Ciberseguridad: identificar amenazas y diseñar controles; documentar la autenticación, la criptografía y los aspectos legales; y registrar pruebas controladas, hallazgos, correcciones y respuesta a incidentes. Las evaluaciones se limitan al código, configuraciones, documentos, capturas y pruebas del propio proyecto. No se realizaron actividades contra sistemas de terceros.

1.1. Metodología y fuentes

Se revisaron la Guía de Entregas de la asignatura; la rama principal main del repositorio del proyecto (commit 1cf9934) y los documentos de análisis, diseño, implementación, ciberseguridad y pruebas. Se contrastaron los documentos históricos con los archivos y pruebas más recientes disponibles al 5 de noviembre de 2026. Cuando un documento antiguo describía un hallazgo como pendiente, pero Testing-06 y el código actual demostraban una corrección posterior, se adoptó el estado más reciente y se indicó la evidencia concreta.

Actualización del repositorio y control de versión. La rama principal main fue revisada en el commit 3142c238843e2b9b4cbdadd42dd71aeb70cf5de5 (5 de noviembre de 2026). El merge del pull request #18 (commit a90c3ed) integró los cambios de la rama cambios-frontend en main, con actualizaciones en el backend, la configuración Docker, la interfaz, la documentación y los registros de pruebas.

Conciliación de documentos con estados históricos. El documento Mecanismos de Autenticación y Criptografía (última actualización indicada: 27/10/2026), especialmente su sección 9, conserva estados anteriores a las correcciones de noviembre: por ejemplo, describe el limitador como no integrado y el cambio de contraseña del alumno/tallerista como no disponible en la interfaz. Para el estado actual se priorizaron la documentación de la API actualizada el 04/11/2026, el código vigente y Testing-06 (04/11/2026). Del mismo modo, las secciones de hallazgos del documento de Hardening y el escaneo histórico de Doc NMAP se trataron como antecedentes, y se contrastaron con Testing-06 y las dos capturas Nmap del 05/11/2026. Los identificadores H-06, H-07 y H-08 de la Tabla 4 son etiquetas de consolidación utilizadas en este informe para agrupar, respectivamente, DEF-11/límite de intentos, la corrección de errores de base de datos registrada en Revision_Coherencia_INAU.md y la obligatoriedad de secretos en Compose; no forman parte de la numeración original H-01 a H-05 del documento de Hardening.

Las pruebas del sistema se documentan en Testing-01 a Testing-06. Testing-06 registra una ejecución asistida en navegador sobre una máquina virtual Ubuntu Server, con API y MySQL en Docker y frontend servido por Nginx. Sus resultados no equivalen a una auditoría independiente ni a pruebas de penetración completas. El script prueba-seguridad.sh se revisó y pasó bash -n, pero no fue ejecutado como parte de la elaboración de este documento; por tanto, sus resultados no se presentan como observados.

Se utilizó ChatGPT (GPT-6) y Claude como apoyo para ordenar y sintetizar la guía, contrastar documentación y código, redactar una guía, crear los diagramas y preparar las figuras a partir de capturas proporcionadas. Las conclusiones técnicas se limitaron a las fuentes disponibles; los espacios de información no acreditada se dejaron abiertos.

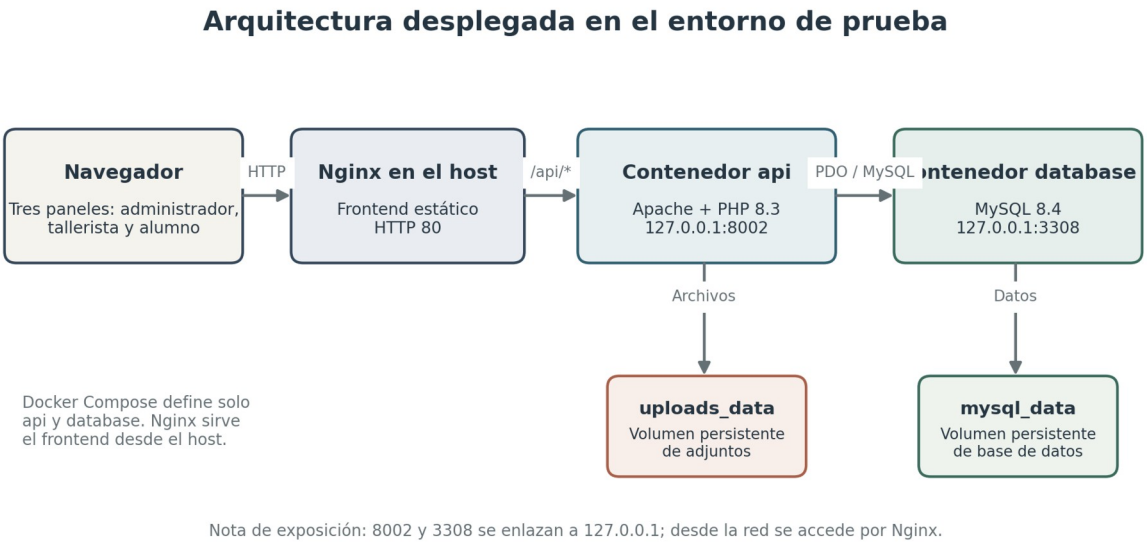
Descripción del sistema

2.1. Arquitectura y componentes

La solución utiliza tres paneles web que consumen una API REST centralizada. En el servidor de prueba, Nginx está instalado en el host y sirve los archivos estáticos del frontend; las solicitudes bajo /api se derivan al contenedor de la API. Docker Compose define dos servicios: api, basado en PHP 8.3 con Apache, y database, basado en MySQL 8.4. El frontend no se ejecuta en un contenedor definido por ese compose. La Figura 1 representa esta arquitectura real y distingue los volúmenes persistentes de la base de datos y los archivos adjuntos (TheNewfutures, 2026e; TheNewfutures, 2026k).

Figura 1

Arquitectura del entorno de prueba de TheNewfutures



Nota. Elaboración propia a partir de compose.yaml, inau-infraestructura-docker.md y Documento de Reconstrucción - Servidor.md. Nginx se ejecuta en el host; Docker Compose declara api y database.

2.2. Tecnologías y organización

Frontend: HTML5, CSS3, Bootstrap 5.3, Bootstrap Icons y JavaScript nativo; contiene paneles diferenciados y un cliente común para la API mediante Fetch.

API: PHP 8.3 y Apache; expone endpoints REST con respuestas JSON y organiza la lógica en capas.

Persistencia: MySQL 8.4 mediante PDO y consultas preparadas.

Autenticación: firebase/php-jwt, firma JWT HS256 y cookie HttpOnly.

Infraestructura: Docker Compose para API y base de datos; Nginx en el host para servir el frontend y actuar como proxy inverso. Estas decisiones se encuentran justificadas en la documentación de arquitectura (TheNewfutures, 2026).

La API sigue una organización por capas: Router y mapa de rutas; AuthMiddleware; Controllers; Validators y DTOs; Services; Repositories; y Response. La documentación técnica registra 58 rutas, agrupadas en autenticación y perfil, alumnos, talleristas, talleres, asignaciones, inscripciones, asistencias, reportes, contenidos, entregas y adjuntos (TheNewfutures, 2026a).

2.3. Datos tratados y alcance

El modelo y las rutas procesan datos de cuentas (nombre, apellido, cédula, correo, teléfono, rol, estado y último acceso), fichas de alumnos (fecha de nacimiento, dirección, referente adulto y centro de referencia), inscripciones, asistencias, tareas, entregas, notas, correcciones y archivos adjuntos. Por tratarse de datos personales y de información asociada a alumnos, el acceso debe limitarse a la función de cada rol y a la relación del usuario con el taller o recurso consultado (Ley N.º 18.331, 2008; TheNewfutures, 2026a).

El sistema no dispone de autorregistro público: las cuentas son creadas o administradas desde el panel correspondiente. Para incorporar la aceptación de los Términos y Condiciones, se agregó una pantalla específica posterior al inicio de sesión. Los paneles de administrador, tallerista y alumno consultan el estado de aceptación del usuario y, cuando corresponde, lo redirigen a dicha pantalla. La integración técnica y su funcionamiento deben considerarse sujetos a las verificaciones pendientes descritas en el apartado 4.3.

2.4. Entorno y límites de la evaluación

El servidor de prueba está descrito como una máquina virtual con Ubuntu Server, Docker para API y MySQL, y Nginx para el frontend. La guía de despliegue propone publicar el sistema con HTTPS mediante Nginx y Certbot; sin embargo, el servidor de laboratorio analizado por Nmap el 5/11/2026 expone HTTP en el puerto 80 y no muestra 443 como abierto. Por tanto, HTTPS está documentado como configuración prevista, pero no está acreditado como aplicado en ese entorno.

Primera entrega: análisis y diseño seguro

3.1. Identificación de amenazas digitales

Las amenazas se definieron atendiendo a los componentes y recursos concretos del proyecto. La valoración de probabilidad e impacto se realiza con la escala de 1 a 3 exigida por la guía de la asignatura. Los valores expresan el riesgo inherente estimado antes de considerar las correcciones verificadas en noviembre; no son una medición estadística ni representan necesariamente el riesgo residual actual.

La Tabla 1 detalla las amenazas, el componente o endpoint concreto y el efecto posible sobre los datos y operaciones del sistema.

Tabla 1

Amenazas digitales identificadas para TheNewfutures

ID y amenaza	Componente / superficie concreta	Riesgo aplicado al proyecto
T1. Phishing y robo de credenciales	Pantalla única de acceso; POST /login; cookie access_token; tabla usuarios.	Un usuario puede entregar su correo y contraseña a una página falsa. La cuenta comprometida podría consultar datos o realizar operaciones del rol correspondiente.
T2. Cross-Site Scripting (XSS)	Formularios, comentarios y contenido mostrado en los tres paneles; módulos JavaScript que representan texto.	Un contenido malicioso podría ejecutarse en el navegador de otro usuario si se interpreta como HTML/JavaScript. La revisión del proyecto registró usos de innerHTML que requieren atención, aunque existen funciones de escape y uso de textContent.
T3. IDOR / Broken Object Level Authorization (BOLA)	GET /entregas/{id}; GET /entregas/{id}/adjuntos; GET /adjuntos/{id}/archivo; servicios de Entrega y Adjunto.	Un alumno podría intentar cambiar IDs de URL para consultar entregas o adjuntos de otro alumno, o un tallerista un recurso fuera de sus talleres asignados.
T4. Inyección SQL (SQLi)	API PHP / MySQL; filtros y operaciones de autenticación, perfiles y recursos; repositorios PDO.	Una entrada incorporada de forma insegura a una consulta podría alterar la instrucción SQL y afectar registros de usuarios, talleres o asistencias. El código revisado utiliza sentencias preparadas PDO; no se reporta una explotación observada.
T5. Exposición directa de archivos adjuntos	Directorio uploads/ y endpoint GET /adjuntos/{id}/archivo.	Si Apache sirviera el directorio de cargas sin comprobar la sesión, un tercero podría descargar materiales o entregas fuera del flujo de permisos. El hallazgo histórico H-02 fue corregido y reprobado.
T6. Exposición de servicios internos	Puertos Docker 8002 (API) y 3308 (MySQL); servidor de prueba.	Si ambos puertos se publicaran en todas las interfaces, un equipo de la red podría conectarse directamente a la API o a MySQL, evitando el punto de entrada Nginx. La configuración por defecto se corrigió para enlazar a 127.0.0.1.
T7. Ransomware o compromiso del servidor	Servidor Ubuntu, contenedores, volumen mysql_data y uploads_data.	El cifrado o alteración de archivos podría interrumpir el servicio y afectar datos de talleres, asistencias, tareas y adjuntos. La restauración requiere respaldar tanto la base como los archivos.

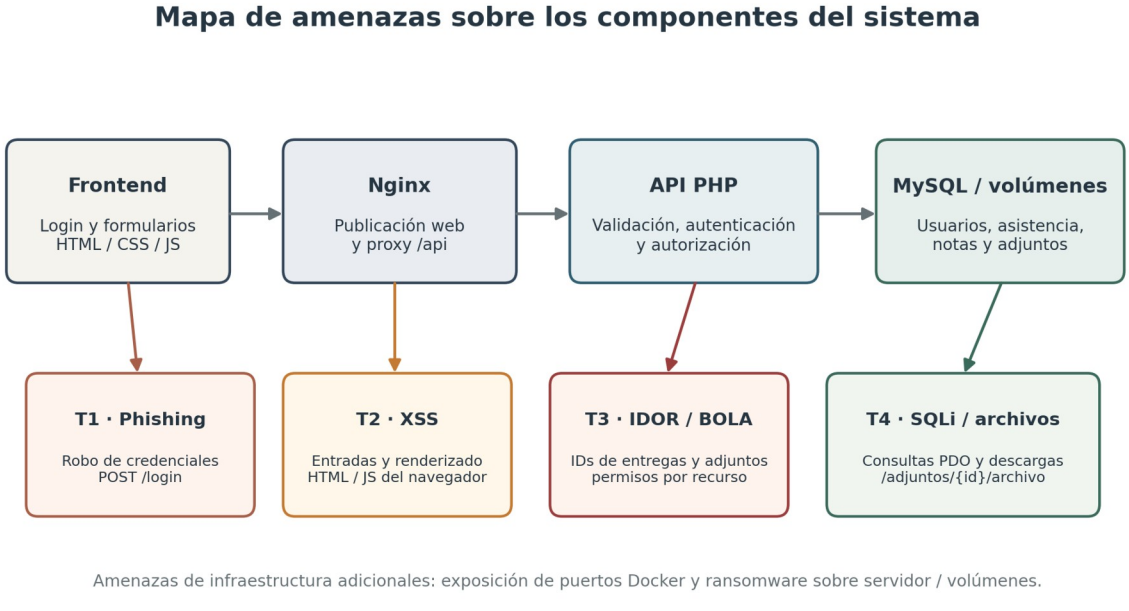
Nota. Elaboración propia a partir de Identificación de amenazas.md, api.md, OWASP Top 10 y OWASP API Security Top 10 (TheNewfutures, 2026d).

3.2. Mapa de riesgos

La Figura 2 relaciona los vectores con los componentes afectados. Las amenazas de phishing y XSS se originan principalmente en la interacción con el usuario; IDOR/BOLA y SQLi afectan a la API y su acceso a datos; la exposición de archivos y puertos afecta el almacenamiento y la infraestructura. Ransomware puede comprometer al host y a los volúmenes persistentes.

Figura 2

Mapa de amenazas digitales por componente



Nota. Elaboración propia a partir de Identificación de amenazas.md, api.md y Hardening de Infraestructura y Contenedores.md.

3.3. Matriz de probabilidad e impacto

La Tabla 2 prioriza las amenazas con la escala de probabilidad e impacto exigida en la guía.

Tabla 2

Matriz de probabilidad e impacto de los riesgos

Amenaza	Probabilidad (1-3)	Impacto (1-3)	P × I	Nivel	Situación al cierre
T1. Phishing / robo de credenciales	3	3	9	Alto	Mitigación parcial: mensajes genéricos, hash y límite de intentos; formación y segundo factor no acreditados.
T2. XSS	2	3	6	Alto	Escape y textContent implementados; uso de innerHTML permanece y requiere revisión.
T3. IDOR / BOLA	2	3	6	Alto	Control por rol y pertenencia probado en CP-35 y CP-37.
T4. SQL Injection	2	3	6	Alto	Uso de PDO preparado; no existe informe SAST que cierre el análisis de código.
T5. Exposición de adjuntos	2	3	6	Alto	Corregido: uploads bloqueado y metadatos no revelan ruta ni nombre interno; CP-20.
T6. Puertos internos expuestos	2	3	6	Alto	Corregido en Compose por defecto; el escaneo de LAN del 5/11 no muestra 8002/3308 abiertos.
T7. Ransomware / pérdida	1	3	3	Medio	Plan documentado; falta fijar RTO, RPO, frecuencia y verificación de respaldos.

Nota. Escala: 1-2 = bajo; 3-4 = medio; 6-9 = alto. Los valores son una evaluación cualitativa del equipo. El nivel refleja el riesgo inherente; la última columna resume los controles y el estado observado tras las correcciones.

3.4. Análisis de impacto

Impacto técnico

La explotación de un acceso indebido o de una inyección SQL podría alterar, consultar o borrar registros de usuarios, talleres, inscripciones, asistencias, notas y entregas. Un XSS podría ejecutar acciones desde el navegador de una persona autenticada. La descarga directa de adjuntos expondría materiales y entregas almacenados en el volumen uploads_data. La publicación de MySQL o de la API en interfaces de red amplía la superficie desde la que se pueden intentar conexiones. Un ransomware o una falla del servidor puede afectar la disponibilidad de los contenedores y de los volúmenes mysql_data y uploads_data. La recuperación no debe limitarse a recrear contenedores:

requiere conservar logs, verificar la integridad de la base y restablecer los archivos adjuntos desde un respaldo válido.

Impacto sobre los usuarios

Los usuarios podrían perder la confidencialidad de su información personal, sus credenciales o los materiales y entregas que forman parte del trabajo del taller. En el caso de alumnos, el impacto puede alcanzar información de identificación, datos de contacto, asistencias, calificaciones, entregas y referencias de adultos responsables. La exposición o alteración de esos datos puede producir perjuicios a las personas, pérdida de confianza y obligaciones de actuación bajo el marco uruguayo de protección de datos personales. La Ley N.º 18.331 reconoce derechos de los titulares sobre sus datos y establece condiciones para su tratamiento; por eso el proyecto debe determinar quién será responsable del tratamiento y cómo se atenderán los derechos de acceso, rectificación, actualización, inclusión y supresión.

3.5. Buenas prácticas de seguridad aplicables

Validación de entradas en frontend y backend. *Amenaza mitigada: datos inválidos, inyección y abuso de formularios.* Aplicación y estado: Los validators PHP verifican correo, cédula, teléfono, campos y tipo/tamaño de adjuntos. La validación backend se ejecuta aun cuando se envían peticiones directas; pruebas CP-05 a CP-07 de Testing-02 y CP-17 de Testing-06.

Sentencias preparadas mediante PDO. *Amenaza mitigada: inyección SQL.* Aplicación y estado: Los repositorios utilizan prepare() y execute() con parámetros. Se mantiene como regla de acceso a MySQL; el análisis SAST aún debe complementar esta revisión (OWASP Foundation, 2021).

Escape de salida y uso de textContent. *Amenaza mitigada: XSS.* Aplicación y estado: El frontend incorpora funciones de escape y textContent. NF-06 verificó que un título con etiqueta script se mostró como texto. Quedan usos de innerHTML que el documento de amenazas registra y deben revisarse (OWASP Foundation, 2021).

Hashing de contraseñas y mensajes genéricos. *Amenaza mitigada: robo de credenciales y enumeración de cuentas.* Aplicación y estado: Se usa password_hash(PASSWORD_DEFAULT) y password_verify(); ante credenciales erróneas se devuelve un mensaje genérico. No se guardan contraseñas en texto plano (OWASP Foundation, s. f.; The PHP Group, s. f.).

Cookie HttpOnly, vencimiento y comprobación de cuenta. *Amenaza mitigada: robo de token mediante JavaScript y uso de sesiones antiguas.* Aplicación y estado: El JWT se envía en cookie HttpOnly, SameSite=Lax y vence según TOKEN_LIFETIME (3600 s por defecto). El middleware consulta el usuario y compara una huella derivada del hash actual. Falta protección CSRF completa y logout no revoca un token copiado.

Control de acceso por rol y pertenencia al recurso. *Amenaza mitigada: IDOR/BOLA y escalada de privilegios.* Aplicación y estado: routes.php aplica admin, tallerista, alumno o auth; los Services verifican asignación al taller y propiedad de entregas/adjuntos. Testing-06 CP-35 y CP-37 aprobados (OWASP Foundation, 2023).

Límite de intentos y tasa general de API. *Amenaza mitigada: fuerza bruta y abuso de solicitudes.* Aplicación y estado: RateLimiter está integrado: máximo 5 fallos por IP + correo cada 5 minutos y 300 solicitudes por minuto por IP. Testing-06 CP-31 verificó el rechazo 429.

Restricción de archivos y descarga autenticada. *Amenaza mitigada: exposición de archivos y adjuntos no permitidos.* Aplicación y estado: AdjuntoValidator limita tamaño a 10 MB y permite PDF/JPG; .htaccess bloquea uploads/ y la descarga oficial requiere sesión. Testing-04 y Testing-06 CP-20.

Variables secretas, puertos locales y reinicio seguro. *Amenaza mitigada: falsificación JWT y exposición de base/API.* Aplicación y estado: Compose exige SECRET_KEY, DB_PASSWORD y MYSQL_ROOT_PASSWORD; API y MySQL se publican en 127.0.0.1 por defecto; restart: unless-stopped se verificó tras reinicio.

HTTPS, encabezados y actualización de dependencias. *Amenaza mitigada: intercepción, filtración de versiones y vulnerabilidades conocidas.* Aplicación y estado: Se documentó Nginx + Certbot, y se ocultaron versiones de servicios (CP-23). HTTPS no está activo en el servidor de prueba; no se documenta aún un procedimiento de actualización periódica de dependencias.

Segunda entrega: implementación segura, criptografía y aspectos legales

4.1. Hashing de contraseñas

El sistema almacena el resultado de password_hash() en la columna usuarios.clave_hash y verifica la contraseña ingresada con password_verify(). El flujo de creación/cambio utiliza PASSWORD_DEFAULT; en la evidencia entregada, el formato visible corresponde a bcrypt ($2y$10$) y la longitud registrada es de 60 caracteres. No se interpreta ni presenta ningún valor de hash individual en este informe.

Un hash de contraseña es una transformación unidireccional: el sistema no recupera la contraseña original. Para comprobar el login, calcula la verificación correspondiente y la compara con el hash almacenado. La sal (salt) es un valor aleatorio que se incorpora al proceso de hash para que contraseñas iguales no produzcan el mismo resultado y para dificultar el uso de tablas precalculadas. Las funciones password_hash() y password_verify() gestionan estos detalles de forma diseñada para contraseñas. No deben sustituirse por MD5 o SHA-1: son funciones rápidas de propósito general, inadecuadas para almacenar contraseñas frente a intentos masivos de adivinación (OWASP Foundation, s. f.; The PHP Group, s. f.).

Evidencia de código

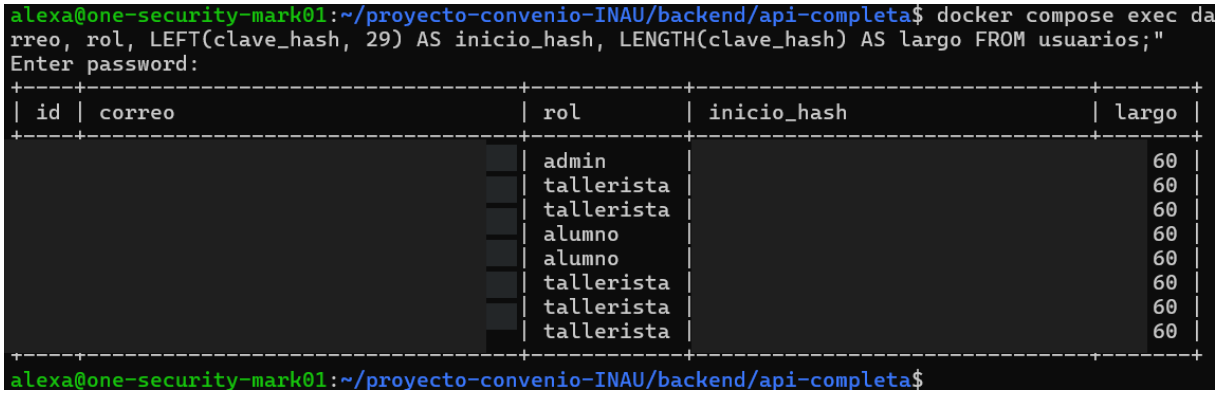
```
// AuthService.php - al cambiar la contraseña
$nuevoHash = password_hash(
    $claveNueva,
    PASSWORD_DEFAULT
);

// User.php - al comprobar el login
public function checkPassword(string $plainPassword): bool
{
    return password_verify($plainPassword, $this->claveHash);
}
```

La evidencia de base de datos se presenta en la Figura 3. La captura original fue censurada para ocultar correos y fragmentos de hashes; se conservan la estructura de la consulta, los roles y la longitud observada. Esta figura demuestra que los valores consultados no aparecen como contraseñas legibles y que la columna utiliza hashes, pero no debe compartirse una exportación con hashes o identificadores de usuarios visibles.

Figura 3

Consulta de la columna de hashes de contraseña en MySQL



Nota. Captura proporcionada por el equipo. Se censuraron identificadores, correos y todos los valores de hash; se conservan únicamente los roles y la longitud observada (60 caracteres). Elaboración propia a partir de una consulta en el entorno de prueba.

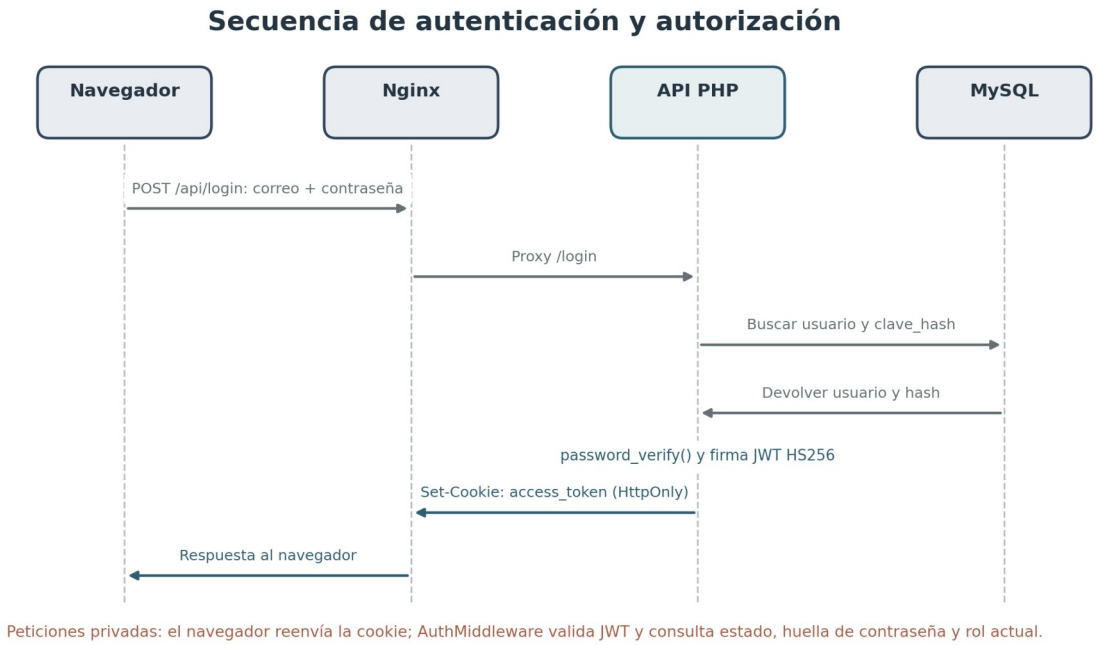
4.2. Autenticación, JWT y gestión de la cookie

El mecanismo real de autenticación no utiliza sesiones PHP ni un token Bearer enviado manualmente en Authorization. El navegador realiza POST /login con correo y contraseña. La API valida la entrada, localiza la cuenta, verifica el hash y comprueba que el usuario esté activo. Si el login es correcto, genera un JWT firmado con HS256 y lo envía en la cookie access_token. El token no se incluye en el cuerpo JSON de la respuesta. El código del frontend no necesita leerlo ni guardarlo en localStorage o sessionStorage: el navegador envía la cookie automáticamente en las solicitudes compatibles con sus atributos (TheNewfutures, 2026, 2026).

En las peticiones privadas, AuthMiddleware lee la cookie, valida la firma y el vencimiento, consulta la cuenta actual en MySQL, comprueba que siga activa y que la huella de contraseña del token coincida con la actual, y toma el rol desde la base de datos. Después aplica el rol requerido por la ruta y los controles del recurso. La Figura 4 resume esta secuencia.

Figura 4

Secuencia de autenticación y autorización basada en cookie HttpOnly



Nota. Elaboración propia a partir de AuthController.php, AuthService.php, Token.php, AuthMiddleware.php y api.md.

Configuración actual del token

Firma: JWT firmado con HS256 mediante firebase/php-jwt.

Almacenamiento: cookie del navegador access_token; el token no se guarda en localStorage ni sessionStorage.

Atributos: HttpOnly y SameSite=Lax. Secure depende de la detección de HTTPS en PHP.

Expiración: TOKEN_LIFETIME; valor predeterminado 3600 segundos (una hora).

Clave: SECRET_KEY en .env; Compose exige que esté definida y el informe no incluye su valor.

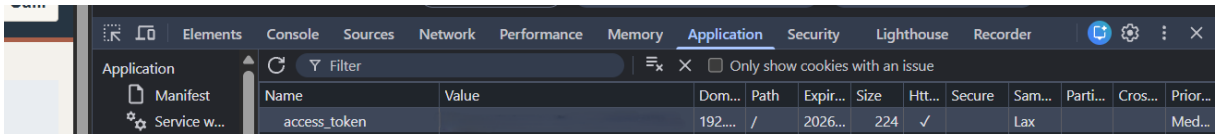
Logout: POST /logout expira la cookie local, sin lista server-side de tokens revocados.

Cambio de contraseña / baja: AuthMiddleware comprueba el usuario y la huella actual; cambiar la contraseña o desactivar el usuario invalida tokens anteriores en las siguientes peticiones. Testing-06 (CP-08 a CP-13) confirma además que el cambio de contraseña está disponible en Mi Perfil para administrador, tallerista y alumno.

La Figura 5 muestra las propiedades de la cookie en el navegador. La captura original incluía el contenido del JWT; se recortó para no divulgarlo. En esa evidencia la columna Secure está vacía, coherente con el servidor de prueba funcionando por HTTP. HttpOnly aparece marcado y SameSite indica Lax. Por tanto, no debe describirse la cookie del entorno de prueba como Secure ni afirmarse que el tráfico esté cifrado mediante HTTPS.

Figura 5

Atributos visibles de la cookie access_token en el navegador



Nota. Captura proporcionada por el equipo y recortada para eliminar el panel que mostraba el valor del JWT. HttpOnly está activado; SameSite es Lax; Secure no aparece marcado en esta sesión HTTP.

Limitaciones de autenticación

El cierre de sesión elimina la cookie local, pero no revoca en el servidor una copia del JWT que alguien hubiera obtenido previamente; ese token podría seguir siendo válido hasta expirar, salvo que la cuenta se desactive o cambie la contraseña. Tampoco se acredita una defensa CSRF completa. La cookie SameSite=Lax reduce determinados envíos entre sitios, pero no sustituye por sí sola un mecanismo CSRF diseñado y probado. El atributo Secure debe quedar activo una vez desplegado el sistema bajo HTTPS. Estas limitaciones deben resolverse antes de operar con información real.

4.3. Términos y Condiciones y Política de Privacidad

Como parte de las mejoras realizadas al proyecto, se incorporaron documentos específicos de Términos y Condiciones y Política de Privacidad, ambos correspondientes a la versión 1.0 de demostración académica. Estos documentos permiten informar a los usuarios sobre las condiciones de utilización del sistema y el tratamiento de los datos personales.

La disponibilidad de los documentos desde el acceso al sistema se muestra en las Figuras N y N+1 del Anexo C, y la pantalla de aceptación, en la Figura N+2.

4.3.1. Términos y Condiciones

El documento de Términos y Condiciones establece la finalidad del Sistema de Gestión de Talleres y las condiciones generales para su utilización. Define los tres roles contemplados por la plataforma: administrador, tallerista y alumno, y describe las responsabilidades correspondientes a cada usuario.

También establece pautas sobre el uso permitido del sistema, la protección de las credenciales, el tratamiento de contenidos y archivos, la seguridad de las cuentas, el uso indebido de la plataforma y las posibles modificaciones de las condiciones.

El apartado sobre datos personales remite a la Política de Privacidad, donde se desarrolla con mayor detalle la información tratada y sus finalidades.

4.3.2. Política de Privacidad

La Política de Privacidad describe las categorías de datos personales que pueden tratarse mediante el sistema, incluyendo datos identificatorios y de contacto, información de alumnos, inscripciones, asistencias, tareas, entregas, calificaciones y archivos adjuntos.

Se detallan las finalidades del tratamiento, los diferentes niveles de acceso según los roles, las medidas técnicas de seguridad y las consideraciones especiales relacionadas con la información de niños y adolescentes.

El documento también contempla los derechos de las personas sobre sus datos personales, la conservación de la información y la comunicación de datos a terceros. Como

marco de referencia se incorpora la Ley N.º 18.331 de Protección de Datos Personales y Acción de Habeas Data.

4.3.3. Incorporación del mecanismo de aceptación

Además de los documentos informativos, se desarrolló una pantalla específica para gestionar la aceptación de los Términos y Condiciones.

El mecanismo está integrado con los tres paneles del sistema. Después de verificar la sesión, el frontend consulta el estado de aceptación del usuario mediante el endpoint `GET /terminos/estado`. Cuando no existe una aceptación registrada para la versión vigente, se redirige al usuario a la pantalla correspondiente.

La aceptación se comunica al backend mediante `POST /terminos/aceptar`. La estructura de persistencia incorpora la tabla `aceptaciones_terminos`, que almacena el identificador del usuario, la versión de los términos aceptada y la fecha de aceptación. Se establece una restricción para evitar registros duplicados de una misma versión por usuario.

La casilla de la interfaz registra expresamente la aceptación de los Términos y Condiciones, mientras que la Política de Privacidad se presenta como un documento disponible para su consulta.

4.3.4. Estado y limitaciones pendientes

Aunque los documentos y el mecanismo de aceptación fueron incorporados al código del proyecto, todavía se requiere completar la revisión y aprobación institucional de los textos. Entre los datos pendientes se encuentran la identificación del responsable del tratamiento, el canal oficial de contacto, los plazos de conservación de la información y la identificación de los proveedores involucrados.

Asimismo, los marcadores de conflicto de integración que había en AuthMiddleware.php se resolvieron en el commit 1cf9934. Antes de considerar validado el control obligatorio de aceptación desde el backend, es necesario ejecutar pruebas específicas que comprueben el comportamiento completo con los tres roles.

Por lo tanto, se considera que el proyecto avanzó en la incorporación documental y técnica de este requisito, pero todavía necesita validación institucional y verificación funcional antes de presentarlo como un mecanismo completamente operativo.

4.4. Análisis estático de código (SAST)

Esta parte queda pendiente de ejecución, por problemas materiales no pudimos realizar el SAST. La existencia de PHPStan, Composer o validadores no sustituye por sí misma el análisis SAST exigido.

La Tabla 3 está reservada para registrar dos hallazgos reales del análisis estático y su corrección verificada.

Tabla 3

Hallazgos del análisis estático y correcciones aplicadas

ID	Herramienta y regla	Archivo / línea	Código antes	Corrección después	Evidencia
SAST-01	[COMPLETAR regla detectada]	[archivo y línea]	[pegar fragmento vulnerable real]	[pegar fragmento corregido]	[Figura: reporte antes y prueba después]
SAST-02	[COMPLETAR regla detectada]	[archivo y línea]	[pegar fragmento vulnerable real]	[pegar fragmento corregido]	[Figura: reporte antes y prueba después]

Tercera entrega: hacking ético, pruebas y respuesta a incidentes

5.1. Análisis dinámico de vulnerabilidades web (DAST): Nmap

Las comprobaciones se ejecutaron sobre el servidor de laboratorio del equipo, no sobre redes de terceros. Existen dos capturas del 5 de noviembre de 2026, con Nmap 7.94SVN y detección de servicios (-sV). La primera utiliza el comando nmap -sV -p- localhost; la segunda, nmap -sV -p- 192.168.1.7. Son escaneos completos de puertos TCP con identificación de servicio.

En la prueba de localhost (Figura 6) se identifican abiertos 22/tcp (OpenSSH 9.6p1), 80/tcp (Nginx), 3308/tcp (MySQL 8.4.13) y 8002/tcp (Apache httpd). Los puertos 3308 y 8002 están publicados en el loopback del host para administración local y comunicación desde Nginx; por tanto, que aparezcan abiertos en localhost no implica que estén disponibles desde otra máquina.

Figura 6

Escaneo Nmap completo de localhost en el servidor de prueba

```
alexa@one-security-mark01:~/proyecto-convenio-INAU/backend/api-completa$   nmap -sV -p- localhost
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-11-05 03:56 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0011s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.20 (Ubuntu Linux; protocol 2.0)
80/tcp   open  http    nginx
3308/tcp open  mysql   MySQL 8.4.13
8002/tcp open  http    Apache httpd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.29 seconds
alexa@one-security-mark01:~/proyecto-convenio-INAU/backend/api-completa$
```

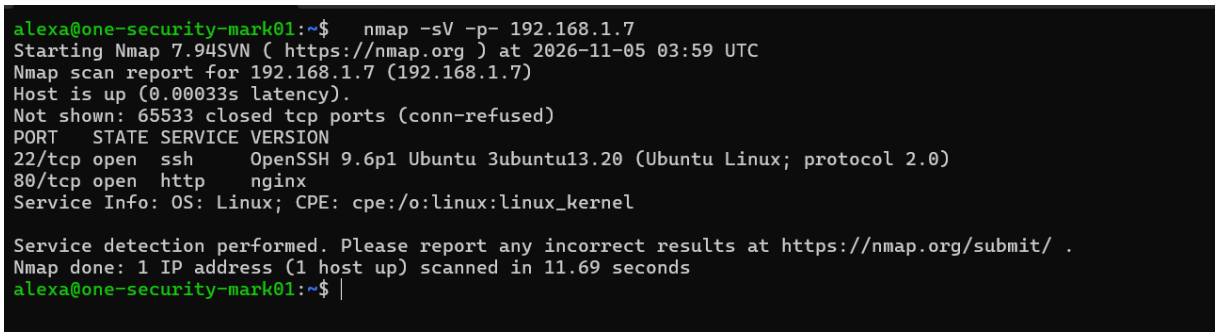
Nota. Captura original del equipo, 5 de noviembre de 2026 . Comando observado: nmap -sV -p- localhost. Elaboración propia a partir de la evidencia aportada.

En la prueba dirigida a 192.168.1.7 (Figura 7) aparecen abiertos 22/tcp (OpenSSH 9.6p1) y 80/tcp (Nginx); la salida indica 65.533 puertos TCP cerrados y no muestra 8002 ni 3308 como abiertos. Esto es consistente con los valores por defecto actuales del Compose,

que enlazan los puertos de API y MySQL a 127.0.0.1. La dirección 192.168.1.7 corresponde a la red local del laboratorio y puede cambiar por DHCP (TheNewfutures, 2026h).

Figura 7

Escaneo Nmap de la dirección de red del servidor de prueba



Nota. Captura original del equipo, 5 de noviembre de 2026. Comando observado: nmap -sV -p- 192.168.1.7. Elaboración propia a partir de la evidencia aportada.

El puerto 22 permite administración SSH y el 80 publica el sitio web de prueba. El puerto 443 no aparece como abierto: el servidor de prueba no tiene HTTPS activo. No se debe presentar Nmap como una certificación de seguridad; el escaneo únicamente describe los puertos y servicios observados desde el propio servidor.

5.2. Auditoría automatizada de API mediante Bash

El script prueba-seguridad.sh contiene diez bloques de comprobación y está diseñado para ejecutarse contra el entorno propio del proyecto. Su sintaxis fue comprobada nuevamente durante la revisión del 5 de noviembre mediante bash -n y no presentó errores de sintaxis.

1. Endpoints privados sin sesión: GET /perfil, /alumnos y /mis-talleres deben responder HTTP 401.
2. Cookie inválida: GET /perfil con un JWT de prueba no válido debe responder HTTP 401.
3. IDOR: un alumno intenta consultar una entrega y sus adjuntos pertenecientes a otro alumno; se espera 403 o 404.
4. Escalada a administrador: el alumno consulta /alumnos y /talleristas e intenta crear un taller; se espera 403.
5. Escalada a tallerista: el alumno consulta entregas o intenta registrar asistencias; se espera 403.
6. Asignación masiva: enviar rol=admin desde el perfil y el cambio de contraseña debe ser rechazado (400 o 422) y no alterar el rol.
7. Entradas inválidas: JSON mal formado y teléfono no válido deben dar 400/422, sin trazas internas.
8. Errores y encabezados: una ruta inexistente debe dar 404 y no revelar versiones ni X-Powered-By.

9. Acceso directo a archivos: /uploads/, /storage/uploads/ y /.env deben responder 403 o 404.
10. Límite de login: cinco intentos erróneos deben dar 401 y el sexto intento con el mismo correo ficticio debe dar 429.

El script inicia sesión con una cuenta de alumno de prueba para ejecutar los casos 3 a 7 y utiliza IDs de recursos de prueba configurables. La contraseña se solicita sin mostrarla y el token se mantiene en memoria temporal. Antes de ejecutarlo, el equipo debe revisar las variables API_BASE, API_DIRECTA, ALUMNO_CORREO, ENTREGA_AJENA, CONTENIDO_ID y TALLER_ID, y confirmar que correspondan a datos de laboratorio. Debe ejecutarse únicamente en el servidor propio o en una máquina de pruebas autorizada.

5.3. Registro de hallazgos y medidas correctivas

La Tabla 4 consolida hallazgos de Nmap, revisión de infraestructura y pruebas de aplicación. Los estados se actualizaron con Testing-06 y el código de la rama principal main, evitando conservar como pendientes observaciones que luego fueron corregidas. Cuando la verificación está documentada en un caso de prueba o revisión de código, se indica la referencia; las únicas capturas nuevas de Nmap se adjuntan como Figuras 6 y 7.

La Tabla 4 registra los hallazgos de infraestructura y aplicación, sus correcciones y la prueba posterior que respalda el estado indicado.

Tabla 4

Registro de hallazgos y medidas correctivas finales

ID / severidad	Hallazgo y descripción	Medida correctiva aplicada	Verificación y estado
H-01 · Alta	API 8002 y MySQL 3308 se publicaban en todas las interfaces.	Compose y plantillas establecen 127.0.0.1:8002 y 127.0.0.1:3308 por defecto.	CP-19 (Testing-06) y Figura 7. No se muestran abiertos en la IP de red. Corregido.
H-02 · Alta	Archivos del directorio uploads podían descargarse directamente; las respuestas exponían ruta y nombre interno.	.htaccess bloquea uploads/; respuestas de adjuntos ya no devuelven ruta ni nombre_archivo.	Testing-04 CP-02 y Testing-06 CP-20. Descarga oficial sigue funcionando. Corregido.
H-03 · Baja	Dos reglas de .gitignore utilizaban Backend con mayúscula, no coincidían con backend/.	Reglas ajustadas a backend/api-completa/uploads/ y storage/uploads/.	Testing-06 CP-21, verificado en el código. Corregido.
H-04 · Media	Los contenedores no se reiniciaban automáticamente tras reiniciar el servidor.	restart: unless-stopped en api y database.	Testing-06 CP-22: tras reinicio los servicios volvieron a funcionar. Corregido.
H-05 · Baja	Nginx/Apache/PHP exponían información de versión.	server_tokens off, ServerTokens Prod, ServerSignature Off y expose_php Off.	Testing-06 CP-23: cabecera Server sin versión y sin X-Powered-By. Corregido.
H-06 · Alta	Fuerza bruta y abuso por solicitudes repetidas.	Límite de 5 intentos por IP+correo cada 5 minutos; límite general de 300 pedidos/minuto/IP.	Testing-06 CP-31 verificó 429 al sexto intento. Corregido y probado.
H-07 · Media	Errores SQL podían revelar detalles internos.	index.php registra el detalle técnico y devuelve un mensaje genérico con HTTP 500.	Testing-06 CP-30: respuesta genérica sin texto de MySQL. Corregido.
H-08 · Alta	Claves de firma y de MySQL podían usar valores de demostración por defecto.	Compose exige SECRET_KEY, DB_PASSWORD y MYSQL_ROOT_PASSWORD.	Testing-06 CP-24, verificado en configuración. Corregido.
DEF-17 · Baja	Encabezados de tabla del panel administrador se muestran en blanco sobre blanco.	No se encontró corrección posterior en las fuentes revisadas.	Testing-06 la registra como abierta; defecto visual pendiente.

Nota. Un hallazgo corregido se considera cerrado solo si existe una nueva verificación. CP-19 a CP-24, CP-30 y CP-31 se encuentran documentados en Testing-06; la referencia es al registro escrito de prueba y al código revisado.

5.4. Plan de respuesta a incidentes

El plan de contingencia del proyecto, con fases de detección, contención, recuperación y lecciones aprendidas, sigue las recomendaciones generales de respuesta a incidentes de NIST (Nelson et al., 2025; TheNewfutures, 2026). Define escenarios de indisponibilidad de la API o MySQL, pérdida o corrupción de la base, ransomware, exposición de secretos, phishing/robo de cuentas, acceso por rol indebido, exposición de puertos, XSS, incidentes con adjuntos y fallas posteriores a actualizaciones. Las señales de alerta deben incluir errores HTTP 500 inusuales, aumentos de 401/403/429, picos de tráfico, accesos a recursos ajenos, descargas directas de uploads, puertos inesperados y errores de disponibilidad de contenedores.

La Tabla 5 define las acciones y responsables previstos para responder a un incidente, junto con los tiempos objetivo orientativos de la guía.

Tabla 5

Matriz de acciones inmediatas ante un incidente

Fase	Acción inmediata	Responsable	Tiempo objetivo de la guía
Contención	Aislar el contenedor afectado o bloquear la IP atacante; registrar hora, IP, servicio y alcance.	Responsable de infraestructura / SSOO; coordinación de Emiliano Sánchez.	Menos de 30 minutos.
Diagnóstico	Revisar logs de Nginx, Docker y API; preservar evidencia y determinar el vector y los datos afectados.	Gabriel Rendon para infraestructura/base; Thiago Ferragut para aplicación.	Menos de 2 horas.
Corrección y recuperación	Aplicar parche o reconstruir servicio; restaurar solo desde respaldo verificado; ejecutar pruebas relacionadas antes de reabrir.	Todo el equipo; ejecuta el responsable del componente.	Menos de 4 horas.
Comunicación	Informar al equipo y a la coordinación; valorar afectación de datos y comunicación a las personas correspondientes conforme al marco aplicable.	Emiliano Sánchez (coordinación del incidente).	Menos de 24 horas.
Lecciones aprendidas	Documentar causa raíz, acciones, pruebas posteriores y cambios del plan.	Todo el equipo; registro documental de Gabriel Rendon.	Menos de 1 semana.

Nota. Los tiempos anteriores son objetivos de respuesta tomados del esquema de la guía de la asignatura; no son tiempos medidos ni compromisos de servicio del proyecto.

Responsables por integrante

Emiliano Sánchez: coordinación y comunicación del incidente; seguridad de cuentas, secretos y exposición de puertos.

Thiago Ferragut: aplicación frontend/backend, permisos, adjuntos y correcciones técnicas del sistema.

Gabriel Rendon: infraestructura, Docker, base de datos, respaldos, registro del incidente y actualización documental.

Respaldos y continuidad

La guía del servidor recomienda crear una copia de MySQL antes de actualizar mediante mysqldump. Esta copia no incluye los archivos adjuntos guardados en uploads_data, por lo que el plan exige respaldarlos por separado y comprobar su restauración. No se debe usar docker compose down -v como solución genérica: el parámetro -v elimina los volúmenes nombrados y puede borrar datos. El plan aún no fija un RTO (tiempo máximo objetivo de recuperación), un RPO (pérdida de datos admisible), una frecuencia de respaldo ni pruebas periódicas de restauración; son datos pendientes de acordar por el equipo antes de un uso real.

5.5. Reflexión ética y responsabilidad profesional

El desarrollo de TheNewfutures – Convenio con INAU nos permitió comprender que la ciberseguridad no consiste únicamente en implementar mecanismos técnicos para evitar ataques o errores. También implica asumir una responsabilidad ética frente a las personas que podrían utilizar el sistema y frente a la información que estas depositan en él. Al tratarse de una plataforma orientada a la gestión de talleres en el contexto de un convenio con INAU, consideramos especialmente importante tener presente que la información administrada puede ser personal y sensible, y que una exposición o utilización inadecuada podría afectar la privacidad y la confianza de sus usuarios.

Como equipo, entendemos que nuestra primera responsabilidad es proteger la confidencialidad, la integridad y la disponibilidad de la información. Esto significa que los datos deben estar accesibles únicamente para las personas autorizadas, conservarse correctamente y encontrarse disponibles cuando el sistema los necesite. Por ese motivo, durante el desarrollo se incorporaron mecanismos como la autenticación mediante JWT, la validación de permisos según el rol del usuario, el uso de consultas preparadas para interactuar con la base de datos y la limitación de intentos de inicio de sesión. Estas medidas representan pasos importantes para reducir riesgos, aunque reconocemos que ninguna aplicación puede considerarse completamente segura por el simple hecho de contar con mecanismos de protección.

También comprendimos que proteger los datos implica actuar con responsabilidad al momento de realizar pruebas y documentar los resultados. Las verificaciones de seguridad

deben efectuarse en entornos autorizados, evitando afectar sistemas, servicios o información de terceros. En nuestro caso, las pruebas de análisis de puertos se realizaron sobre el entorno de desarrollo disponible y no tuvieron como objetivo acceder a sistemas ajenos. Asimismo, al incorporar capturas como evidencia en el informe, consideramos necesario ocultar identificadores, correos electrónicos, valores de hashes y otros datos que no era necesario divulgar. Esto demuestra que la responsabilidad sobre la información no termina cuando se encuentra una vulnerabilidad: también se mantiene al comunicar los hallazgos.

Otro aspecto importante fue reconocer las limitaciones del propio proyecto. Durante la revisión identificamos medidas que todavía requieren mejoras o verificaciones adicionales, como la configuración de HTTPS en el servidor de pruebas, la protección completa frente a ataques CSRF, la definición de una política de copias de seguridad y recuperación, y la revisión de determinados usos de `innerHTML`. También quedaron pendientes el análisis SAST con una herramienta especializada y la ejecución completa del script de pruebas de seguridad contra el sistema. Consideramos que ocultar estas limitaciones o presentar como completadas tareas que todavía no fueron verificadas sería una falta de responsabilidad profesional. Por el contrario, registrar los problemas, explicar su impacto y proponer acciones correctivas forma parte de un trabajo transparente y confiable.

La privacidad merece una atención particular. Un sistema que administra información de alumnos, talleristas y administradores debe limitar la recopilación y el acceso a los datos a lo que realmente necesita para funcionar. Además, las personas deben poder comprender qué información se utiliza, con qué finalidad y bajo qué condiciones. En este sentido, reconocemos que los Términos y Condiciones y la Política de Privacidad todavía necesitan una definición y validación adecuadas. No sería correcto incorporar textos legales genéricos ni afirmar que existe un consentimiento plenamente implementado cuando ese mecanismo aún no fue resuelto. Antes de considerar esos documentos definitivos, corresponde definir el procedimiento junto con los responsables del proyecto y los criterios institucionales aplicables.

Desde la responsabilidad profesional, también consideramos fundamental trabajar de manera organizada, comunicar los riesgos entre los integrantes y no tomar decisiones únicamente por conveniencia o rapidez. Cada integrante debe comprender que una modificación aparentemente pequeña puede tener consecuencias sobre la seguridad o el funcionamiento general del sistema. Por eso, documentar los cambios, realizar pruebas, revisar el código y mantener una comunicación clara son prácticas que ayudan a prevenir errores y permiten que el equipo pueda responder ante ellos.

Finalmente, este proyecto nos permitió entender que desarrollar software implica una responsabilidad que va más allá de cumplir con los requisitos técnicos o entregar una

aplicación funcional. Quienes trabajan en tecnología deben actuar con honestidad, respetar la privacidad, utilizar sus conocimientos de forma ética y reconocer cuándo una solución todavía necesita mejoras. Como equipo, asumimos que la seguridad es un proceso continuo y no una tarea que termina al finalizar el desarrollo. Nuestro compromiso es seguir identificando riesgos, corregir las debilidades encontradas y comunicar con claridad el estado real del sistema. De esta manera, buscamos que TheNewfutures no sea solamente una solución funcional, sino también un proyecto desarrollado con criterios de responsabilidad, transparencia y respeto hacia sus posibles usuarios.

Conclusiones

El trabajo permitió pasar de identificar riesgos generales a relacionarlos con rutas, paneles, tablas y componentes concretos. Se documentó una arquitectura con separación entre frontend, API, base de datos y almacenamiento de adjuntos; el control de acceso por rol y por recurso; la utilización de consultas preparadas y hashing de contraseñas; y la gestión de tokens en cookies HttpOnly. Las seis rondas de pruebas y, especialmente, Testing-06 permitieron verificar correcciones sobre puertos, archivos adjuntos, secretos, errores, reinicios y límites de intentos.

La última ronda del repositorio registra 38 casos aprobados y deja constancia de que las pruebas fueron manuales o asistidas, con datos de laboratorio, un navegador y sin pruebas completamente automatizadas. El escaneo Nmap del 5/11 identifica MySQL y Apache abiertos solo en localhost, mientras que en la dirección de red del servidor aparecen SSH y HTTP. El puerto 443 no aparece abierto; por tanto, el servidor de prueba no está utilizando HTTPS.

Persisten riesgos y tareas que impiden describir la solución como certificada o lista para información real: protección CSRF completa; invalidación server-side de un JWT copiado al cerrar sesión; HTTPS activo y atributo Secure en la cookie; revisión de los usos de innerHTML; política formal de actualización de dependencias; SAST con dos hallazgos reales corregidos; se incorporaron los documentos de Términos y Condiciones y Política de Privacidad, junto con una interfaz y estructura de persistencia para registrar la aceptación de la versión vigente. Sin embargo, aún deben completarse la revisión y aprobación

institucional, la resolución de los datos pendientes y las pruebas de funcionamiento integral del mecanismo. ; y respaldo con frecuencia, RTO y RPO definidos. También queda abierto el defecto visual DEF-17 y el dato de prueba DEF-08 (un archivo guía ausente en el servidor).

Referencias

American Psychological Association. (2020). Publication manual of the American Psychological Association (7th ed.). https://doi.org/10.1037/0000165-000

Guía de Entregas - Electiva Ciberseguridad. (2026). [Guía del curso proporcionada por la asignatura].

Ley N.º 18.331. Ley de protección de datos personales y acción de habeas data. (2008, 11 de agosto). Registro Nacional de Leyes y Decretos. IMPO. https://www.impo.com.uy/bases/leyes/18331-2008

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST SP 800-61r3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

OpenAI. (2026). ChatGPT (GPT-6) [Modelo de lenguaje]. https://chatgpt.com/

OWASP Foundation. (2021). OWASP Top 10: 2021. https://owasp.org/Top10/

OWASP Foundation. (2023). OWASP API Security Top 10: 2023. https://owasp.org/API-Security/editions/2023/en/0x11-t10/

OWASP Foundation. (s. f.). Password storage cheat sheet. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

Rendon, G. (2026, 5 de noviembre). Guía rápida para el informe de ciberseguridad.

TheNewfutures. (2026). Documentación de la API [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/04-implementacion/api.md

TheNewfutures. (2026). Declaración de compromiso ético en el uso de IA [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/01-gestion/Documentos%20del%20equipo/Declaración%20de%20Etica%20en%20el%20uso%20de%20IA.md

TheNewfutures. (2026). Hardening de infraestructura y contenedores [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/05-Ciberseguridad/Hardening%20de%20Infraestructura%20y%20Contenedores.md

TheNewfutures. (2026). Identificación de amenazas digitales [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/05-Ciberseguridad/Identificación%20de%20amenazas.md

TheNewfutures. (2026). Infraestructura Docker para TheNewfutures [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/04-implementacion/inau-infraestructura-docker.md

TheNewfutures. (2026). Justificación tecnológica y arquitectura [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/03-diseño/Justificacion%20Tecnologica.md

TheNewfutures. (2026). Mecanismos de autenticación y criptografía [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/05-Ciberseguridad/Mecanismos_Autenticacion_Criptografia_INAU.md

TheNewfutures. (2026). Nmap aplicado al proyecto [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/05-Ciberseguridad/Doc%20NMAP.md

TheNewfutures. (2026). Plan de contingencia [Documento interno del proyecto]. Repositorio GitHub, rama main.

https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/05-Ciberseguridad/Plan%20de%20Contingencia.md

TheNewfutures. (2026). Project Charter: TheNewfutures - Plataforma de gestión de talleres en convenio con INAU [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/01-gestion/Charter.md

TheNewfutures. (2026). Reconstrucción del servidor [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/04-implementacion/Documento%20de%20Reconstruccion%20-%20Servidor.md

TheNewfutures. (2026). Testing-06: regresión, hardening y verificación de correcciones [Documento interno del proyecto]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/docs/04-implementacion/Testing/Testing-06.md

Rendon, G. (2026, 5 de noviembre). Guía rápida para el informe de ciberseguridad.

The PHP Group. (s. f.). password_hash. En PHP Manual. https://www.php.net/manual/es/function.password-hash.php

TheNewfutures. (2026). Política de Privacidad (versión 1.0 de demostración) [Documento HTML del sistema]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/frontend/privacidad.html

TheNewfutures. (2026). Términos y Condiciones (versión 1.0 de demostración) [Documento HTML del sistema]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/frontend/terminos.html

TheNewfutures. (2026). Pantalla de aceptación de Términos y Condiciones

[Documento HTML del sistema]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/frontend/aceptar-terminos.html

TheNewfutures. (2026). Lógica de aceptación de Términos y Condiciones [Código fuente JavaScript]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/frontend/js/aceptar-terminos.js

TheNewfutures. (2026). Rutas de la API para Términos y Condiciones [Código fuente PHP]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/backend/api-completa/routes.php

TheNewfutures. (2026). Controlador de Términos y Condiciones [Código fuente PHP]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/backend/api-completa/controllers/TerminosController.php

TheNewfutures. (2026). Esquema de base de datos y registro de aceptaciones [Código fuente SQL]. Repositorio GitHub, rama main. https://github.com/emilianoandressanchezhernandez-ui/proyecto-convenio-INAU/blob/main/backend/api-completa/DataBase/inau_talleres.sql

Anexos

Anexo A. Script prueba-seguridad.sh

Se incorpora el contenido completo del script. Para proteger un dato de prueba, el correo fijo del alumno fue sustituido en esta copia por el marcador CORREO_ALUMNO_DE_PRUEBA. Antes de ejecutar, configurar ALUMNO_CORREO con una cuenta del entorno de laboratorio.

```
#!/usr/bin/env bash
# ======================================================================
# prueba-seguridad.sh
# Auditoría automatizada de la API REST - Sistema de Gestión de Talleres
# en Convenio con INAU (TheNewfutures).
#
# Qué hace: envía pedidos HTTP a la API y comprueba que responda como
# se espera ante accesos sin sesión, tokens inválidos, acceso a datos
# de otro usuario (IDOR), escalada de privilegios, campos no permitidos,
# datos inválidos, errores que filtren información, acceso directo a
# los archivos subidos y repetición de intentos de inicio de sesión.
#
# Regla ética: ejecutar SOLO sobre el sistema propio del grupo.
#
# Uso (en el servidor):
#   chmod +x prueba-seguridad.sh && ./prueba-seguridad.sh
#
# Variables opcionales (se pueden definir antes del comando):
#   API_BASE        URL de la API a través de Nginx  (por defecto
http://localhost/api)
#   API_DIRECTA     URL del contenedor de la API      (por defecto
http://localhost:8002)
#   ALUMNO_CORREO   correo de un alumno de prueba     (por defecto
CORREO_ALUMNO_DE_PRUEBA)
#   ENTREGA_AJENA   id de una entrega de OTRO alumno  (por defecto 2)
#   CONTENIDO_ID    id de una tarea del taller        (por defecto 4)
#   TALLER_ID       id de un taller                   (por defecto 1)
#
# La contraseña del alumno se pide por teclado y no se muestra ni se
# guarda. El script no crea, modifica ni borra datos: los pedidos de
# escritura se envían con datos inválidos o vacíos, de modo que, aun si
# el permiso fallara, la validación los rechazaría.
# ======================================================================

set -u

API_BASE="${API_BASE:-http://localhost/api}"
API_DIRECTA="${API_DIRECTA:-http://localhost:8002}"
ALUMNO_CORREO="${ALUMNO_CORREO:-CORREO_ALUMNO_DE_PRUEBA}"
ENTREGA_AJENA="${ENTREGA_AJENA:-2}"
CONTENIDO_ID="${CONTENIDO_ID:-4}"
TALLER_ID="${TALLER_ID:-1}"
TOTAL_TESTS=10

# Archivos temporales: cuerpo y encabezados de cada respuesta.
# Se borran al terminar, pase lo que pase.
TMP_DIR="$(mktemp -d)"
CUERPO="$TMP_DIR/cuerpo.txt"
ENCABEZADOS="$TMP_DIR/encabezados.txt"
trap 'rm -rf "$TMP_DIR"' EXIT

HALLAZGOS=0
SIN_HALLAZGO=0
```

```
ESTADO=""          # último código HTTP recibido
SESION=""          # token de la sesión del alumno (nunca se muestra)
FALLAS_TEST=0      # comprobaciones fallidas dentro del test actual
DETALLE_TEST=""    # detalle de lo que falló

# ------------------------------------------------------------------
# Funciones auxiliares
# ------------------------------------------------------------------

# Escapa comillas y barras para armar JSON a mano sin herramientas extra.
json_escape() {
    local texto="$1"
    texto="${texto//\\/\\\\}"
    texto="${texto//\"/\\\"}"
    printf '%s' "$texto"
}

# peticion MÉTODO URL [CUERPO_JSON] [con_sesion|sin_sesion|cookie_invalida]
# Guarda el código HTTP en ESTADO, el cuerpo en $CUERPO y los
# encabezados en $ENCABEZADOS.
peticion() {
    local metodo="$1" url="$2" datos="${3:-}" modo="${4:-sin_sesion}"
    local args=(-s -o "$CUERPO" -D "$ENCABEZADOS" -w '%{http_code}' -X
"$metodo" --max-time 15)

    case "$modo" in
        con_sesion)      args+=(-H "Cookie: access_token=$SESION") ;;
        cookie_invalida) args+=(-H "Cookie:
access_token=token.invalido.de.prueba") ;;
    esac

    if [ -n "$datos" ]; then
        args+=(-H "Content-Type: application/json" --data "$datos")
    fi

    ESTADO="$(curl "${args[@]}" "$url" 2>/dev/null)"
    [ -z "$ESTADO" ] && ESTADO="000"
}

# comprobar "descripción" "códigos aceptados separados por espacio"
# Compara ESTADO con los códigos esperados y acumula el resultado.
comprobar() {
    local descripcion="$1" esperados="$2" codigo
    for codigo in $esperados; do
        if [ "$ESTADO" = "$codigo" ]; then
            printf '      ok  %-58s HTTP %s\n' "$descripcion" "$ESTADO"
            return
        fi
    done
    if [ "$ESTADO" = "000" ]; then
        printf '      !!  %-58s sin respuesta (revise la URL)\n' "$descripcion"
    else
        printf '      !!  %-58s HTTP %s (se esperaba %s)\n' "$descripcion"
"$ESTADO" "$esperados"
    fi
    FALLAS_TEST=$((FALLAS_TEST + 1))
    DETALLE_TEST="$DETALLE_TEST $descripcion: HTTP $ESTADO;"
}

# sin_filtracion "descripción": revisa que el cuerpo no muestre detalles
# internos (trazas de PHP, errores SQL, rutas del servidor).
sin_filtracion() {
```

```
    local descripcion="$1"
    if grep -qiE 'SQLSTATE|PDOException|Stack trace|Fatal
error|Warning:|/var/www/html' "$CUERPO"; then
        printf '      !!  %-58s detalle interno en la respuesta\n'
"$descripcion"
        FALLAS_TEST=$((FALLAS_TEST + 1))
        DETALLE_TEST="$DETALLE_TEST $descripcion: muestra detalle interno;"
    else
        printf '      ok  %-58s sin detalle interno\n' "$descripcion"
    fi
}

iniciar_test() {
    FALLAS_TEST=0
    DETALLE_TEST=""
    printf '[TEST %s/%s] %s\n' "$1" "$TOTAL_TESTS" "$2"
}

cerrar_test() {
    if [ "$FALLAS_TEST" -eq 0 ]; then
        printf '  >>> SIN HALLAZGO - %s\n' "$1"
        SIN_HALLAZGO=$((SIN_HALLAZGO + 1))
    else
        printf '  >>> HALLAZGO -%s\n' "$DETALLE_TEST"
        HALLAZGOS=$((HALLAZGOS + 1))
    fi
}

linea() { printf '%s\n'
"========================================================================"; }

# ------------------------------------------------------------------------
# Inicio de sesión del alumno de prueba (necesario para los tests 3 a 7)
# ------------------------------------------------------------------------

linea
printf 'PRUEBAS DE SEGURIDAD HTTP - Sistema de Gestión de Talleres (INAU)\n'
printf '  API Base: %s\n' "$API_BASE"
printf '  Fecha:    %s\n' "$(date '+%d/%m/%Y %H:%M')"
linea

if [ -z "${ALUMNO_CLAVE:-}" ]; then
    printf 'Contraseña del alumno de prueba (%s): ' "$ALUMNO_CORREO"
    read -rs ALUMNO_CLAVE
    printf '\n'
fi

peticion POST "$API_BASE/login" \
    "{\"correo\":\"$(json_escape "$ALUMNO_CORREO")\",\"clave\":\"$(json_escape
"$ALUMNO_CLAVE")\"}"
unset ALUMNO_CLAVE

# Guardar en memoria el token de la cookie que devolvió el login
# (encabezado Set-Cookie). No se muestra ni se escribe en disco.
SESION="$(grep -i '^Set-Cookie: access_token=' "$ENCABEZADOS" | head -1 \
    | sed -E 's/^[Ss]et-[Cc]ookie: access_token=([^;]*).*/\1/' | tr -d '\r')"
: > "$ENCABEZADOS"

if [ "$ESTADO" != "200" ] || [ -z "$SESION" ]; then
    printf 'No se pudo iniciar sesión como alumno (HTTP %s). Revise el correo y
la contraseña.\n' "$ESTADO"
    exit 1
```

```
fi
printf 'Sesión de alumno iniciada (%s).\n\n' "$ALUMNO_CORREO"

# ------------------------------------------------------------------
# TEST 1: rutas privadas sin sesión -> 401
# ------------------------------------------------------------------
iniciar_test 1 "Autenticación en endpoints privados (sin sesión)"
peticion GET "$API_BASE/perfil";       comprobar "GET /perfil sin sesión" "401"
peticion GET "$API_BASE/alumnos";      comprobar "GET /alumnos sin sesión"
"401"
peticion GET "$API_BASE/mis-talleres"; comprobar "GET /mis-talleres sin sesión"
"401"
cerrar_test "La API respondió 401 a los pedidos sin sesión."

# ------------------------------------------------------------------
# TEST 2: token inválido -> 401
# ------------------------------------------------------------------
iniciar_test 2 "Token de sesión inválido o alterado"
peticion GET "$API_BASE/perfil" "" cookie_invalida
comprobar "GET /perfil con un token inválido" "401"
cerrar_test "La API rechazó el token inválido con 401."

# ------------------------------------------------------------------
# TEST 3: IDOR, el alumno intenta ver la entrega de otro alumno -> 403
# ------------------------------------------------------------------
iniciar_test 3 "Control de acceso IDOR (entrega $ENTREGA_AJENA de otro alumno)"
peticion GET "$API_BASE/entregas/$ENTREGA_AJENA" "" con_sesion
comprobar "GET /entregas/$ENTREGA_AJENA" "403 404"
peticion GET "$API_BASE/entregas/$ENTREGA_AJENA/adjuntos" "" con_sesion
comprobar "GET /entregas/$ENTREGA_AJENA/adjuntos" "403 404"
cerrar_test "El alumno no puede ver datos de otro alumno."

# ------------------------------------------------------------------
# TEST 4: escalada de privilegios, alumno -> funciones del administrador
# ------------------------------------------------------------------
iniciar_test 4 "Escalada de privilegios: alumno a administrador"
peticion GET  "$API_BASE/alumnos"     ""   con_sesion; comprobar "GET /alumnos"
"403"
peticion GET  "$API_BASE/talleristas" ""   con_sesion; comprobar "GET
/talleristas" "403"
peticion POST "$API_BASE/talleres"    "{}" con_sesion; comprobar "POST
/talleres (cuerpo vacío)" "403"
cerrar_test "Acciones de administrador denegadas con 403."

# ------------------------------------------------------------------
# TEST 5: escalada de privilegios, alumno -> funciones del tallerista
# ------------------------------------------------------------------
iniciar_test 5 "Escalada de privilegios: alumno a tallerista"
peticion GET  "$API_BASE/contenidos/$CONTENIDO_ID/entregas" "" con_sesion
comprobar "GET /contenidos/$CONTENIDO_ID/entregas" "403"
peticion POST "$API_BASE/talleres/$TALLER_ID/asistencias" "{}" con_sesion
comprobar "POST /talleres/$TALLER_ID/asistencias (cuerpo vacío)" "403"
cerrar_test "Acciones de tallerista denegadas con 403."

# ------------------------------------------------------------------
# TEST 6: campos no permitidos (asignación masiva del rol)
# ------------------------------------------------------------------
iniciar_test 6 "Campos no permitidos: intento de cambiar el rol"
peticion PATCH "$API_BASE/perfil/clave" '{"rol":"admin"}' con_sesion
comprobar "PATCH /perfil/clave con {\"rol\":\"admin\"}" "400 422"
peticion PATCH "$API_BASE/perfil" '{"rol":"admin"}' con_sesion
comprobar "PATCH /perfil con {\"rol\":\"admin\"}" "400 422"
```

```
cerrar_test "La API rechazó el campo rol."

# ---------------------------------------------------------------------
# TEST 7: datos inválidos -> 400/422, nunca 500 ni detalles internos
# ---------------------------------------------------------------------
iniciar_test 7 "Datos no válidos en formularios"
peticion POST "$API_BASE/login" '{"correo": "sin-cierre'
comprobar "POST /login con JSON mal formado" "400 422"
sin_filtracion "POST /login con JSON mal formado"
peticion POST "$API_BASE/login" '{"correo":"no-es-un-correo","clave":""}'
comprobar "POST /login con correo inválido y clave vacía" "400 401 422"
sin_filtracion "POST /login con correo inválido"
peticion PATCH "$API_BASE/perfil" '{"telefono":"abc"}' con_sesion
comprobar "PATCH /perfil con teléfono \"abc\"" "400 422"
sin_filtracion "PATCH /perfil con teléfono inválido"
cerrar_test "Los datos inválidos se rechazaron sin errores internos."

# ---------------------------------------------------------------------
# TEST 8: errores y encabezados sin información del servidor
# ---------------------------------------------------------------------
iniciar_test 8 "Errores y encabezados sin información interna"
peticion GET "$API_BASE/ruta-que-no-existe"
comprobar "GET /ruta-que-no-existe" "404"
sin_filtracion "Respuesta 404"
if grep -qi '^X-Powered-By:' "$ENCABEZADOS"; then
    printf '      !!  %-58s presente\n' "Encabezado X-Powered-By"
    FALLAS_TEST=$((FALLAS_TEST + 1)); DETALLE_TEST="$DETALLE_TEST X-Powered-By
presente;"
else
    printf '      ok  %-58s ausente\n' "Encabezado X-Powered-By"
fi
SERVIDOR="$(grep -i '^Server:' "$ENCABEZADOS" | head -1 | tr -d '\r')"
if printf '%s' "$SERVIDOR" | grep -qE '[0-9]+\.[0-9]+'; then
    printf '      !!  %-58s %s\n' "Encabezado Server sin versión" "$SERVIDOR"
    FALLAS_TEST=$((FALLAS_TEST + 1)); DETALLE_TEST="$DETALLE_TEST $SERVIDOR;"
else
    printf '      ok  %-58s %s\n' "Encabezado Server sin versión" "${SERVIDOR:-
(sin encabezado)}"
fi
cerrar_test "Las respuestas no revelan versiones ni detalles internos."

# ---------------------------------------------------------------------
# TEST 9: acceso directo a los archivos subidos -> no debe dar 200
# ---------------------------------------------------------------------
iniciar_test 9 "Acceso directo a archivos subidos (sin pasar por la API)"
peticion GET "$API_DIRECTA/uploads/"
comprobar "GET $API_DIRECTA/uploads/" "403 404"
peticion GET "$API_DIRECTA/storage/uploads/"
comprobar "GET $API_DIRECTA/storage/uploads/" "403 404"
peticion GET "$API_DIRECTA/.env"
comprobar "GET $API_DIRECTA/.env" "403 404"
cerrar_test "Los archivos internos no se pueden descargar directamente."

# ---------------------------------------------------------------------
# TEST 10: límite de intentos de inicio de sesión -> 429
# Usa un correo inventado, así que no bloquea ninguna cuenta real.
# ---------------------------------------------------------------------
iniciar_test 10 "Límite de intentos de inicio de sesión"
CORREO_FALSO="prueba.limite.$(date +%s)@example.com"
for intento in 1 2 3 4 5; do
    peticion POST "$API_BASE/login" "{\"correo\":\"$CORREO_FALSO\",\"clave\":
\"incorrecta$intento\"}"
```

```
done
comprobar "Intento 5 con credenciales incorrectas" "401"
peticion POST "$API_BASE/login" "{\"correo\":\"$CORREO_FALSO\",\"clave\":
\"incorrecta6\"}"
comprobar "Intento 6 con el mismo correo" "429"
cerrar_test "El sexto intento fue bloqueado con HTTP 429."

# ------------------------------------------------------------------
# Cierre: se termina la sesión del alumno y se muestra el resumen
# ------------------------------------------------------------------
peticion POST "$API_BASE/logout" "" con_sesion
SESION=""

linea
printf '  RESUMEN: Hallazgos %s | Sin hallazgo %s\n' "$HALLAZGOS"
"$SIN_HALLAZGO"
linea

[ "$HALLAZGOS" -eq 0 ]
```

Anexo B. Ejemplo de respuesta de adjuntos sin rutas internas

La guía de capturas incluida transcribe la respuesta de GET /api/contenidos/4/adjuntos, en la que cada elemento devuelve metadatos necesarios para la interfaz, pero no la ruta física ni el nombre interno del archivo. Se reproduce un ejemplo parcial como evidencia documental; la captura de red puede añadirse cuando el equipo la obtenga.


```
{
  "ok": true,
  "datos": [
    {
      "id": 6,
      "contenido_id": 4,
      "entrega_id": null,
      "nombre_original": "imagen.jpg",
      "tipo_mime": "image/jpeg",
      "tamano_bytes": 771,
      "fecha_subida": "2026-11-01 23:35:49"
    },
    {
      "id": 5,
      "contenido_id": 4,
      "entrega_id": null,
      "nombre_original": "consigna.pdf",
      "tipo_mime": "application/pdf",
      "tamano_bytes": 69,
      "fecha_subida": "2026-11-01 23:35:49"
    }
  ]
}
```


Nota. Ejemplo transcrito en la guía de trabajo de Rendon (2026). No es una captura de pantalla independiente; la verificación de la corrección se registra en Testing-06, CP-20.

Anexo C. Documentos legales y evidencia de aceptación

Términos y Condiciones

Sistema de Gestión de Talleres - INAU

Versión 1.0

Versión final 1.0 de demostración académica.

1. Objeto y finalidad

El Sistema de Gestión de Talleres es una plataforma informática destinada a facilitar la organización, administración y seguimiento de actividades educativas y formativas.

Permite gestionar talleres, alumnos, talleristas, inscripciones, asistencias, materiales educativos, tareas, entregas, calificaciones y reportes.

2. Usuarios y acceso

El acceso está reservado a usuarios que dispongan de una cuenta habilitada. Las cuentas son administradas por personal autorizado y no existe registro público.

Cada usuario debe utilizar sus credenciales personales y respetar los permisos correspondientes a su rol.

3. Roles y permisos

El sistema contempla tres roles principales:

- **Administrador:** gestiona talleres, usuarios, inscripciones, asignaciones, asistencias y reportes según las funcionalidades habilitadas.
- **Tallerista:** consulta los talleres asignados, administra las actividades autorizadas, registra asistencias y realiza correcciones.
- **Alumno:** consulta sus talleres, contenidos, tareas, entregas y asistencias.

4. Responsabilidades de los usuarios

Los usuarios se comprometen a:

- Mantener la confidencialidad de sus credenciales.
- Utilizar el sistema únicamente para las finalidades previstas.
- Respetar la privacidad y los datos personales de otras personas.
- No intentar acceder a información o funcionalidades sin autorización.
- No alterar, eliminar ni compartir información indebidamente.
- Comunicar posibles problemas de seguridad al responsable del sistema.

5. Contenidos, tareas y archivos

La plataforma permite publicar materiales educativos, administrar tareas, registrar entregas y consultar correcciones.

Los archivos cargados deberán estar relacionados con las actividades autorizadas. No se permite incorporar archivos maliciosos, contenidos ilícitos o información personal de terceros sin autorización o fundamento legítimo.

6. Datos personales

El sistema utiliza información necesaria para la identificación de usuarios, administración de cuentas y seguimiento de las actividades educativas.

Entre los datos tratados pueden encontrarse nombres, apellidos, documentos de identidad, información de contacto, inscripciones, asistencias y entregas.

Los detalles del tratamiento deberán consultarse en la Política de Privacidad .

7. Seguridad de las cuentas

Las cuentas son personales y no deben compartirse. Los usuarios deberán informar cualquier sospecha de acceso no autorizado o utilización indebida de sus credenciales.

8. Disponibilidad y mantenimiento

La plataforma puede requerir actualizaciones, mantenimiento técnico o interrupciones necesarias para su funcionamiento.

9. Uso indebido

El incumplimiento de estas condiciones podrá dar lugar a medidas proporcionadas conforme a los procedimientos institucionales y normativos aplicables.

10. Modificaciones

Los términos podrán actualizarse cuando cambien las funcionalidades, las necesidades institucionales o los requisitos aplicables.

Cuando corresponda, el sistema solicitará la aceptación de una nueva versión.

11. Consultas y contacto

Las consultas deberán dirigirse al responsable institucional designado para el sistema.

Responsable y canal oficial de contacto: pendientes de confirmación institucional.

12. Aceptación de las condiciones

La aceptación de estos términos implica que el usuario ha tenido acceso a su contenido y se compromete a respetar las condiciones de uso establecidas, sin perjuicio de sus derechos legales.

El sistema podrá registrar la identidad del usuario, la versión aceptada y la fecha de aceptación.

Política de Privacidad

Sistema de Gestión de Talleres - INAU

Versión 1.0

Versión final 1.0 de demostración académica.

---

1. Introducción

Esta Política de Privacidad describe el tratamiento de datos personales asociado al Sistema de Gestión de Talleres desarrollado en el marco del proyecto de convenio INAU.

La plataforma está destinada a facilitar la administración de talleres y el seguimiento de actividades educativas.

El tratamiento de datos personales deberá realizarse conforme a la normativa vigente en Uruguay, especialmente la Ley N.° 18.331 de Protección de Datos Personales y su reglamentación aplicable.

2. Responsable del tratamiento

La responsabilidad institucional sobre el tratamiento de los datos personales deberá ser determinada por las entidades que administren y utilicen el sistema en su implementación efectiva.

Institución responsable: pendiente de confirmación.

Canal oficial de contacto: pendiente de confirmación.

3. Datos personales tratados

Según el tipo de cuenta y las actividades realizadas, la plataforma puede almacenar y consultar las siguientes categorías de información:

Correo electrónico y teléfono Fecha de nacimiento, dirección y referente adulto Talleres e inscripciones Asistencias y observaciones Tareas, entregas y archivos Calificaciones y correcciones Fechas de registro y último acceso

Información	Finalidad
Nombre, apellido y cédula	Identificación de usuarios.
Gestión de cuentas y contacto.	
Administración de fichas de alumnos.	
Organización de la participación en actividades.	
Seguimiento de la participación.	
Desarrollo y seguimiento de actividades educativas.	
Seguimiento del desempeño en las actividades.	
Administración y seguridad de las cuentas.	

4. Finalidades del tratamiento

La información tratada mediante el sistema se utiliza para las siguientes finalidades:

- Administrar las cuentas de usuarios.
- Identificar a los alumnos y talleristas.
- Organizar talleres e inscripciones.
- Registrar y consultar asistencias.
- Publicar contenidos y actividades.
- Gestionar entregas, correcciones y calificaciones.
- Elaborar reportes relacionados con los talleres.
- Proteger las cuentas y controlar el acceso a las funcionalidades.

5. Acceso a la información

El sistema contempla tres roles de usuario: administrador, tallerista y alumno.

Los administradores cuentan con funciones de gestión general, mientras que los talleristas y alumnos tienen acceso a las operaciones habilitadas según su participación en los talleres.

El acceso a la información está sujeto a los mecanismos de autenticación y autorización implementados en la plataforma.

6. Seguridad de los datos

La plataforma incorpora mecanismos técnicos destinados a reducir los riesgos de acceso no autorizado y exposición de información.

Entre ellos se encuentran la autenticación de usuarios, el almacenamiento de contraseñas mediante funciones de hash, los controles de acceso por roles y la protección de archivos privados.

Estas medidas deben complementarse con una configuración segura del servidor, mantenimiento técnico, copias de seguridad y procedimientos institucionales adecuados.

7. Información de niños y adolescentes

El sistema puede tratar información correspondiente a niños y adolescentes que participan en los talleres.

El tratamiento de esta información deberá atender especialmente a sus derechos, a la finalidad educativa y a las autorizaciones o fundamentos legales que correspondan.

La aceptación de los términos de uso por parte de un alumno no sustituye las autorizaciones de sus representantes cuando estas resulten legalmente necesarias.

8. Conservación de los datos

Los periodos de conservación de la información deberán ser definidos por la institución responsable, considerando las finalidades del tratamiento y las obligaciones legales aplicables.

La desactivación de una cuenta no implica necesariamente la eliminación automática de los registros asociados a talleres, asistencias o entregas.

9. Comunicación de datos a terceros

El acceso o la comunicación de información fuera de los usuarios autorizados deberá responder a una finalidad legítima y cumplir la normativa aplicable.

Antes de la puesta en producción, la institución responsable deberá identificar los proveedores de infraestructura y cualquier destinatario de los datos.

10. Derechos de las personas

Las personas titulares de los datos podrán ejercer los derechos reconocidos por la normativa aplicable, incluidos los de acceso, rectificación, actualización, inclusión o supresión cuando correspondan.

Las solicitudes deberán dirigirse al responsable institucional del tratamiento mediante el canal que se establezca oficialmente.

11. Modificaciones de esta política

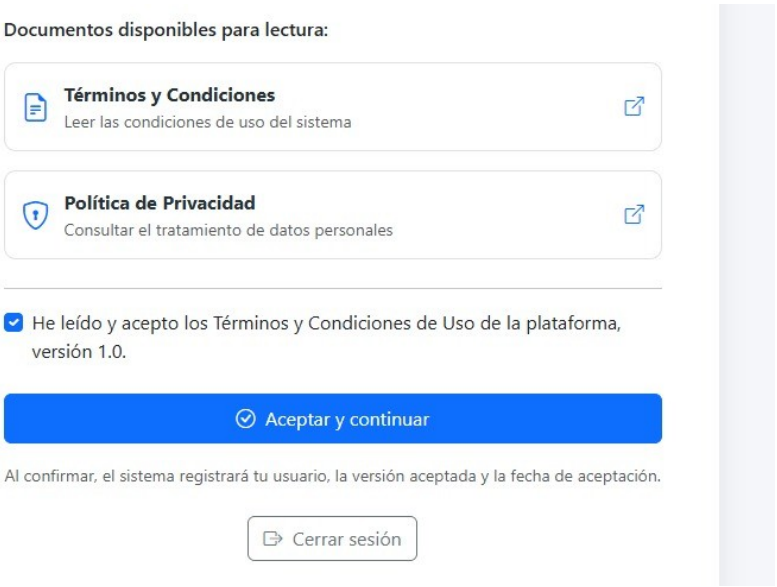
Esta Política de Privacidad podrá actualizarse ante modificaciones en las funcionalidades del sistema, las finalidades del tratamiento o la normativa aplicable.

Las modificaciones relevantes deberán comunicarse de manera apropiada a los usuarios.

12. Consultas

Para realizar consultas sobre el tratamiento de datos personales, los usuarios deberán utilizar el canal institucional que se determine para la plataforma.

Datos de contacto: pendientes de confirmación institucional.


Documentos disponibles para lectura:
Términos y Condiciones
Leer las condiciones de uso del sistema
Política de Privacidad
Consultar el tratamiento de datos personales
He leído y acepto los Términos y Condiciones de Uso de la plataforma, versión 1.0.
Aceptar y continuar
Al confirmar, el sistema registrará tu usuario, la versión aceptada y la fecha de aceptación.
Cerrar sesión

Anexo D. Espacio de reflexión ética grupal

El desarrollo de TheNewfutures nos permitió comprender que la ciberseguridad no consiste únicamente en implementar mecanismos técnicos para evitar ataques o errores. También implica asumir una responsabilidad ética frente a las personas que podrían utilizar el sistema y frente a la información que estas depositan en él. Al tratarse de una plataforma orientada a la gestión de talleres en el contexto de un convenio con INAU, consideramos especialmente importante tener presente que la información administrada puede ser personal y sensible, y que una exposición o utilización inadecuada podría afectar la privacidad y la confianza de sus usuarios.

Como equipo, entendemos que nuestra primera responsabilidad es proteger la confidencialidad, la integridad y la disponibilidad de la información. Esto significa que los datos deben estar accesibles únicamente para las personas autorizadas, conservarse correctamente y encontrarse disponibles cuando el sistema los necesite. Por ese motivo, durante el desarrollo se incorporaron mecanismos como la autenticación mediante JWT, la validación de permisos según el rol del usuario, el uso de consultas preparadas para interactuar con la base de datos y la limitación de intentos de inicio de sesión. Estas medidas representan pasos importantes para reducir riesgos, aunque reconocemos que ninguna aplicación puede considerarse completamente segura por el simple hecho de contar con mecanismos de protección.

También comprendimos que proteger los datos implica actuar con responsabilidad al momento de realizar pruebas y documentar los resultados. Las verificaciones de seguridad deben efectuarse en entornos autorizados, evitando afectar sistemas, servicios o información de terceros. En nuestro caso, las pruebas de análisis de puertos se realizaron sobre el entorno de desarrollo disponible y no tuvieron como objetivo acceder a sistemas ajenos. Asimismo, al incorporar capturas como evidencia en el informe, consideramos necesario ocultar identificadores, correos electrónicos, valores de hashes y otros datos que no era necesario divulgar. Esto demuestra que la responsabilidad sobre la información no termina cuando se encuentra una vulnerabilidad: también se mantiene al comunicar los hallazgos.

Otro aspecto importante fue reconocer las limitaciones del propio proyecto. Durante la revisión identificamos medidas que todavía requieren mejoras o verificaciones adicionales, como la configuración de HTTPS en el servidor de pruebas, la protección completa frente a ataques CSRF, la definición de una política de copias de seguridad y recuperación, y la revisión de determinados usos de `innerHTML`. También quedaron pendientes el análisis

SAST con una herramienta especializada y la ejecución completa del script de pruebas de seguridad contra el sistema. Consideramos que ocultar estas limitaciones o presentar como completadas tareas que todavía no fueron verificadas sería una falta de responsabilidad profesional. Por el contrario, registrar los problemas, explicar su impacto y proponer acciones correctivas forma parte de un trabajo transparente y confiable.

La privacidad merece una atención particular. Un sistema que administra información de alumnos, talleristas y administradores debe limitar la recopilación y el acceso a los datos a lo que realmente necesita para funcionar. Además, las personas deben poder comprender qué información se utiliza, con qué finalidad y bajo qué condiciones. En este sentido, reconocemos que los Términos y Condiciones y la Política de Privacidad todavía necesitan una definición y validación adecuadas. No sería correcto incorporar textos legales genéricos ni afirmar que existe un consentimiento plenamente implementado cuando ese mecanismo aún no fue resuelto. Antes de considerar esos documentos definitivos, corresponde definir el procedimiento junto con los responsables del proyecto y los criterios institucionales aplicables.

Desde la responsabilidad profesional, también consideramos fundamental trabajar de manera organizada, comunicar los riesgos entre los integrantes y no tomar decisiones únicamente por conveniencia o rapidez. Cada integrante debe comprender que una modificación aparentemente pequeña puede tener consecuencias sobre la seguridad o el funcionamiento general del sistema. Por eso, documentar los cambios, realizar pruebas, revisar el código y mantener una comunicación clara son prácticas que ayudan a prevenir errores y permiten que el equipo pueda responder ante ellos.

Finalmente, este proyecto nos permitió entender que desarrollar software implica una responsabilidad que va más allá de cumplir con los requisitos técnicos o entregar una aplicación funcional. Quienes trabajan en tecnología deben actuar con honestidad, respetar la privacidad, utilizar sus conocimientos de forma ética y reconocer cuándo una solución todavía necesita mejoras. Como equipo, asumimos que la seguridad es un proceso continuo y no una tarea que termina al finalizar el desarrollo. Nuestro compromiso es seguir identificando riesgos, corregir las debilidades encontradas y comunicar con claridad el estado real del sistema. De esta manera, buscamos que TheNewfutures no sea solamente una solución funcional, sino también un proyecto desarrollado con criterios de responsabilidad, transparencia y respeto hacia sus posibles usuarios.

Custodia de datos personales de alumnos y talleristas:

Aporte del hacking ético y del análisis continuo a la calidad:

Diferencia entre pruebas autorizadas y ataque no autorizado:

Compromiso con la Ley N.º 18.331 y privacidad: